



SCENARIO CARD

SCENARIO-01

MULTI-REGION BREACH WITH DATA SOVEREIGNTY ISSUES

COMPLEXITY: ADVANCED

AFFECTED REGIONS: US + EU + Asia

PRIMARY CHALLENGE: Different legal requirements for different regions

DESCRIPTION

Breach affects customer data in multiple countries with different privacy laws: US (California); notify without unreasonable delay; CCPA statutory damages fuel class actions; EU (GDPR): 72-hour notification deadline; fines up to €20M or 4% of global turnover, whichever is HIGHER; Asia (various): Different deadlines and requirements in each country; Data residency requirements mean: EU customer data cannot be transferred to US servers; Forensics must happen in country where data is stored; Different regulators in each country demand investigation; Different notification laws require different messages;

KEY COMPLICATIONS

Timeline Conflict: EU regulators demand notification faster than the domestic clock; US requires notification without unreasonable delay; Asia varies; Legal Conflict: EU GDPR vs. US lawful intercept (conflicting requirements); Investigation: Must conduct forensics in multiple jurisdictions simultaneously; Costs: Multi-region response = much higher costs;

TEAM DECISION POINTS

1. Which region to prioritize (cannot satisfy all simultaneously) 2. How to conduct forensics across jurisdictions 3. How to notify customers differently per region 4. How to handle conflicting regulatory requirements

SPECIAL EVENTS (ADDED TO THE TIMELINE AT SETUP)

Turn 2: EU regulators demand notification – a second ACTION-10 play (EU filing) is due by end of Turn 4; Turn 5: International regulators demand investigation coordination (Regulator trust -5 if investigation is below 25%); Turn 6: Data residency complication – if the EU filing was missed, Regulator trust -10 per turn (in place of, not stacked with, the core EVENT=02 escalation);

COST IMPLICATIONS

Multi-region legal and forensics overhead: see Difficulty below; Regulatory fines can stack across jurisdictions (narrative-only); Notification costs: translations, different templates, regulatory filings;

CONTINUED IN MODULE RULES

INCIDENT ZERO - DISASTER RECOVERY



SCENARIO CARD

SCENARIO-04

INSIDER THREAT REVEALED MID-CRISIS

COMPLEXITY: ADVANCED

ATTACKER: Current employee; not external hacker

PRIMARY CHALLENGE: Organizational trauma and trust collapse

DESCRIPTION

Breach investigation of external breach, forensic team discovers: The "external breach" had help from insider; Employee provided attacker with access/credentials; Employee may have also exfiltrated data; Employee is still working at company (not yet caught);

KEY COMPLICATIONS

Who is involved?; Single rogue employee? Conspiracy (multiple employees)?; Which departments are involved?; Motive; Disgruntled employee selling data; Corporate espionage (hired by competitor); Theft for personal gain; Political/ideological motivation; Scope; What other systems did insider compromise?; What data did they access/steal; How long were they active; Are there other insiders? HR/legal; Fire the employee immediately (risks legal action); Continue employment while investigating (ethics question); Involve law enforcement (police investigation); Civil litigation from employee (wrongful termination claims);

ORGANIZATIONAL IMPACT

Trust in employees collapses; Morale plummets (people suspect each other); Staff paranoia increases; Executive distraction (investigation insider);

SPECIAL EVENTS

Turn 2: Forensics discovers insider involvement; Turn 3: HR/Legal team must decide: fire or investigate?; Turn 4: If fired, wrongful termination lawsuit likely; Turn 4: If not fired, employee may destroy more evidence; Turn 5: Law enforcement investigation (if reported to police);

TEAM DECISIONS

1. Immediately fire employee (legal risk but stops damage) 2. Continue employment while investigating (ethical but risky) 3. Involve law enforcement: criminal investigation, slow 4. Settle potential lawsuits preemptively (expensive)

INVESTIGATION COMPLICATION

Cannot trust employee's explanations; Must verify what employee had access to; Must recover deleted data/logs; Must interview other employees; Investigation takes much longer (suspicious of everyone);

CONTINUED IN MODULE RULES

INCIDENT ZERO - DISASTER RECOVERY



SCENARIO CARD

SCENARIO-07

RANSOMWARE + DATA BREACH + BUSINESS EMAIL COMPROMISE

COMPLEXITY: ADVANCED+

MULTIPLE SIMULTANEOUS COMPROMISES: Systems encrypted + data stolen + email account compromised

PRIMARY CHALLENGE: Responding to multiple attack objectives simultaneously

DESCRIPTION

Not a single attack but multiple overlapping compromises: 1. Ransomware: File servers encrypted (production stops, cannot access files) 2. Data Breach: Database stolen (customer data exfiltrated) 3. Email Compromise: CEO's email account compromised (attacker can send as CEO)

KEY COMPLICATIONS

Attacker has multiple leverage points: "Pay ransom or systems stay encrypted" (operational pressure); "Pay to prevent data publication" (financial/reputational pressure); "Stop responding or we'll send fake CEO email" (social engineering pressure); Investigation difficulty; Multiple attack vectors to investigate; May be different attackers or coordinated campaign; Each compromise has different timeline; Cannot determine if attacks are related or independent; Remediation priorities clash; Bcrypt systems immediately (get operations back); Recover stolen data (prevent publication); Secure CEO email account (prevent further compromise); Cannot do all three at once (budget/time constraints);

SPECIAL COMPLICATIONS

Fake CEO Email Risk; Attacker sends email as CEO; "Approve" emergency spending; "Authorize" data transfers; "Orders" employee actions; Teams cannot tell if email is real; Timeline Acceleration; Email compromise creates urgency; Attacker can impersonate executives; Must immediately notify all employees; Breach of trust (employees distrust CEO emails);

SPECIAL EVENTS

Turn 1: Discovery of ransomware + data breach; Turn 2: Discovery of CEO email compromise; Turn 3: Fake CEO email sends "emergency transfer" (employees confused); Turn 4: Attacker threatens to send more fake emails (escalation); Turn 5: Ransom deadline, data publication deadline, email account deadline (all converging);

INVESTIGATION COMPLICATION

Three separate forensics investigations (expensive); Each compromise requires different approach; Timelines may overlap (more complexity); May be related (same attacker?) or unrelated/unlikely;

INCIDENT ZERO - DISASTER RECOVERY



SCENARIO CARD

SCENARIO-02

RANSOMWARE WITH EXTORTION THREAT

COMPLEXITY: ADVANCED

ATTACKER DEMAND: \$10M ransom or threaten to sell/publish data

PRIMARY CHALLENGE: Responding to extortion threats

DESCRIPTION

Attacker not only encrypted data but also stole data and threatens public disclosure: "Pay up or we publish 500GB of customer PII on dark web" (demand = 20 Budget; narrative "S10M" for a large enterprise); Attacker provides proof of data access (sample file); Extortion email sent to CEO and board; Attacker sets the deadline at the start of Turn 5 (the core ACTION-13 ransom deadline);

KEY COMPLICATIONS

Payment Question: Pay ransom or not?; Paying; Funding criminal enterprise, no guarantee of data deletion; Not paying; Risk of data publication (massive PR disaster); Disclosure Dilemma: Tell customers about extortion threat?; Yes: Customers fear data will be published; No: If data is published, looks like cover-up; Law Enforcement: FBI recommends not paying (incentivizes more attacks); Backup Reliance: Can you recover without paying?;

TIMELINE PRESSURE (SPECIAL EVENTS ADDED AT SETUP)

Turn 1: Extortion email; ransom deadline set at start of Turn 5; Turn 2: First partial data publication (attacker shows they have data); Media trust -5; Turn 3: Attacker lowers price (negotiation attempt; pure roleplay – ACTION-13 costs are unchanged); Turn 5: Deadline reached – resolve ACTION-13 as printed (publish if unpaid; -2 turns if NEGOTIATE);

FINANCIAL DILEMMA

Ransom: payment may violate OFAC sanctions if the actor is sanctioned; many insurers restrict or exclude ransom coverage; Recovery from backup; Slow (if backups exist); Data publication: Regulatory fines + lawsuits (potentially \$50M+ liability; narrative-only); Public disclosure: stock price crash, customer loss;

TEAM DECISIONS

1. Pay ransom? (Risk: Encourages future attacks, no guarantee) 2. Attempt to recover from backup? (Risk: Slow recovery, data loss) 3. Notify customers before/after data publication? (Risk: Either way is bad) 4. Notify regulators? (Required, but shows full extent of damage)

CONTINUED IN MODULE RULES

INCIDENT ZERO - DISASTER RECOVERY



SCENARIO CARD

SCENARIO-05

CRITICAL INFRASTRUCTURE BREACH (SAFETY/LIVES AT RISK)

COMPLEXITY: ADVANCED+

SECTOR: Utilities, Healthcare, Transportation, Manufacturing

PRIMARY CHALLENGE: Physical safety takes priority over cybersecurity response

DESCRIPTION

Breach affects critical infrastructure where compromise could cause physical harm: Healthcare: Hospital network compromise during surgery (patient safety risk); Utilities: Power grid compromise during storm (people without power/heat); Transportation: Traffic system compromise (accidents possible); Manufacturing: Production system compromise (equipment failure); Key Complication: Safety > Security Cannot shut down system for forensics if people are harmed; Cannot remediate if it requires system downtime; Incidental response must preserve operational safety; Balances security downtime with operational continuity;

REGULATORY ESCALATION

CISA (Cybersecurity Infrastructure Security Agency) involved immediately; National Incident Command System (NICS) may take over; Government mandates response (not optional); Military/intelligence agencies may be involved; Cannot investigate without government approval;

SPECIAL CONSIDERATIONS

Lives are at stake (not just data); Response priorities are: Safety – Containment – Investigation; Traditional forensics may be impossible (system must stay operational); Attacker knows system is critical (leverage for negotiation);

SPECIAL EVENTS

Turn 1: CISA declaration of critical infrastructure incident; Turn 2: Government takes partial control of response (may override company decisions); Turn 3-4: Attacker threatens system shutdown (extortion using safety risk); Turn 5: Coordinated meeting/government briefings (national security implications);

TEAM DECISIONS

1. Continue operations (risk of safety incident) or shut down (risk to people without service)? 2. Engage with government agencies (lose control of response) 3. Negotiate with attacker (payment may violate OFAC sanctions if the actor is sanctioned; government will weigh in) 4. Accept potential service interruption (for safety)

CONTINUED IN MODULE RULES

INCIDENT ZERO - DISASTER RECOVERY



SCENARIO CARD

SCENARIO-06

STOCK PRICE CRASH (PUBLIC COMPANY PANIC)

COMPLEXITY: ADVANCED

TRIGGER: Negative media coverage + analyst downgrades

PRIMARY CHALLENGE: Managing financial crisis alongside security crisis

DESCRIPTION

Public company stock price crashes following breach announcement: News of breach announced; Stock drops 10-20% in first day; Short-sellers amplify negative sentiment; Analysts downgrade stock rating; Institutional investors sell (panic selling); Stock drops 30-50% or more;

KEY COMPLICATIONS

Financial Crisis; Company loses market value (\$1B+ in some cases); Credit rating downgrade possible; Difficulty accessing credit markets; Acquisition at depressed price possible; Board/Shareholder Panic; Shareholders demand CEO removal; Board may fire executives immediately; Board may accept lowball acquisition offer; Media coverage of internal turmoil; Business Disruption; Employee morale crashes (stock is part of compensation); Key employees leave (seeking more stable companies); Customer confidence drops; Supplier payment delays (credit rating issue); Business slows due to loss of employee focus;

INVESTOR PSYCHOLOGY

Fear-driven selling (stock is "falling knife"); Rumors spread (company is bankruptcy risk); Technical traders amplify selling (algorithmic trading); Recovery takes months/years even if breach is minor;

SPECIAL EVENTS

Turn 1: Stock drops 20% (breach announcement); Turn 2: Analyst downgrades (stock drops another 15%); Turn 3: Media "Death Spiral" narrative ("Company Doomed"); Turn 4: Short-seller report (negative narrative amplified); Turn 5: Activist investor demands board change; Turn 6: Acquisition offer from vulture investor (lowball); Turn 7: Board may accept acquisition (loses independence);

TEAM DECISIONS

1. Focus on crisis response (stock takes care of itself) 2. Spend effort on investor relations (PR effort) 3. Respond to activist pressure (appeasement or defiance)? 4. Accept acquisition offer or fight it?

CONTINUED IN MODULE RULES

INCIDENT ZERO - DISASTER RECOVERY



SCENARIO CARD

SCENARIO-03

SUPPLY CHAIN COMPROMISE (VENDOR BREACH AFFECTS CUSTOMERS)

COMPLEXITY: ADVANCED

VENDOR: Breach compromises customers' data at YOUR company's data store

PRIMARY CHALLENGE: Managing responsibility for vendor compromise

DESCRIPTION

Investigation reveals attacker didn't target your company directly—they compromised a vendor you use: Your company uses cloud storage vendor (e.g., competitor to AWS); That vendor was breached; Attacker gained access to YOUR customer data stored at vendor; Question: Who is responsible? You? Vendor? Both?;

KEY COMPLICATIONS

Liability Question: You're liable to customers (you selected vendor); Vendor is liable (their security failure); Customers might sue both; Vendor Response; Vendor may be uncooperative (deny liability); Vendor may be bankrupt (vendor company collapse during breach); Vendor may not investigate properly; Notification Question: Tell customers you chose bad vendor?; Or just notify about data breach without explaining vendor?; Either way looks bad; Investigation; Must investigate vendor (not your own systems); Vendor may not cooperate; Limited forensic access (you don't control vendor systems); Regulatory agencies may blame you anyway;

RESPONSIBILITY & LIABILITY

Customer lawsuits: "You failed to vet vendor properly"; Regulatory fines: "You failed to oversee third-party risk"; Vendor lawsuits: "Vendor refuses to pay damages"; Vendor bankruptcy: "Vendor can't pay, customers turn to you";

TEAM DECISIONS

1. Blame vendor (legally risky, looks bad) 2. Share responsibility (legally safer, but costs more) 3. Quickly terminate vendor relationship (looks reactive) 4. Demand vendor pay for notification/remediation (vendor may refuse)

SPECIAL EVENTS

Turn 1: Discovery that vendor was breached; Turn 2: Vendor denies liability / claims it's your responsibility; Turn 3: Regulatory agency demands to know vendor details; Turn 4: First customer lawsuit against both you AND vendor; Turn 5: Vendor declares bankruptcy (can't pay damages);

CONTINUED IN MODULE RULES

INCIDENT ZERO - DISASTER RECOVERY



SCENARIO CARD

SCENARIO-06

STOCK PRICE CRASH (PUBLIC COMPANY PANIC)

COMPLEXITY: ADVANCED

TRIGGER: Negative media coverage + analyst downgrades

PRIMARY CHALLENGE: Managing financial crisis alongside security crisis

DESCRIPTION

Public company stock price crashes following breach announcement: News of breach announced; Stock drops 10-20% in first day; Short-sellers amplify negative sentiment; Analysts downgrade stock rating; Institutional investors sell (panic selling); Stock drops 30-50% or more;

KEY COMPLICATIONS

Financial Crisis; Company loses market value (\$1B+ in some cases); Credit rating downgrade possible; Difficulty accessing credit markets; Acquisition at depressed price possible; Board/Shareholder Panic; Shareholders demand CEO removal; Board may fire executives immediately; Board may accept lowball acquisition offer; Media coverage of internal turmoil; Business Disruption; Employee morale crashes (stock is part of compensation); Key employees leave (seeking more stable companies); Customer confidence drops; Supplier payment delays (credit rating issue); Business slows due to loss of employee focus;

INVESTOR PSYCHOLOGY

Fear-driven selling (stock is "falling knife"); Rumors spread (company is bankruptcy risk); Technical traders amplify selling (algorithmic trading); Recovery takes months/years even if breach is minor;

SPECIAL EVENTS

Turn 1: Stock drops 20% (breach announcement); Turn 2: Analyst downgrades (stock drops another 15%); Turn 3: Media "Death Spiral" narrative ("Company Doomed"); Turn 4: Short-seller report (negative narrative amplified); Turn 5: Activist investor demands board change; Turn 6: Acquisition offer from vulture investor (lowball); Turn 7: Board may accept acquisition (loses independence);

TEAM DECISIONS

1. Focus on crisis response (stock takes care of itself) 2. Spend effort on investor relations (PR effort) 3. Respond to activist pressure (appeasement or defiance)? 4. Accept acquisition offer or fight it?

CONTINUED IN MODULE RULES

INCIDENT ZERO - DISASTER RECOVERY

